

The Personal Data Protection Agency has imposed an administrative monetary fine on the data controller – the debt collection agency B2 Kapital d.o.o. in the amount of 2,265,000.00 euros (17,065,642.50 kuna) due to the following established violations of the General Data Protection Regulation:

1. The data controller did not clearly and accurately inform its respondents about the processing of their personal data through the notice on personal data processing (privacy policy), regarding the legal basis for the refund of overpaid funds, which is contrary to the provision of Article 13, paragraph 1 of the General Data Protection Regulation. This resulted in non-transparent processing of personal data of the respondents (i.e., incorrect information regarding the legal basis for processing under Article 6, paragraph 1 of the General Data Protection Regulation), of which there were (at least) 132,652 at the time of the supervision, and the privacy policy remained unchanged, and the violation has not yet been remedied, i.e., it has been ongoing since May 25, 2018, to the present day.
2. Contrary to the provision of Article 28, paragraph 3 of the General Data Protection Regulation, the data controller did not conclude a contract for the processing of personal data with the processor for the service of monitoring simple consumer bankruptcy, thereby jeopardizing the security of personal data of 83,896 respondents (OIB), since concluding a contract with the processor is one of the security measures that ensures that the rules for processing personal data are clearly defined, their flow in the business relationship between the controller and the processor, and to ensure that the data controller verifies that the processor meets the technical and organizational measures of protection when processing personal data of a large number of respondents. It was established that this violation lasted from the acceptance of the offer for providing the service of monitoring simple consumer bankruptcy, i.e., from February 14, 2019, to February 26, 2021, when the business cooperation was terminated.
3. The data controller did not take appropriate technical and organizational measures to protect personal data processing, which is contrary to Article 32, paragraph 1, points b) and d), and paragraph 2 of the General Data Protection Regulation. By failing to take appropriate measures, the security of personal data of all respondents (at least 132,652 at the time of supervision) was compromised, specifically their basic identification data (at least in the structure: name and surname, date of birth, and OIB) and consequently all personal data recorded in the debt collection agency's storage systems, which are of a financial nature and thus quite sensitive. The procedure established that the violation has lasted at least since 2019 and has not yet been remedied, all due to the failure to take appropriate protective measures. Namely, the Personal Data Protection Agency received an anonymous complaint in December 2022 stating that there had been unauthorized processing of a large number of personal data of individuals – debtors by the debt collection agency, and a USB stick was attached containing personal data in the structure of name and surname, date of birth, and OIB for a total of 77,317 individuals who had outstanding debts to credit institutions, which were purchased by the debt collection agency based on a contract of assignment.

Based on its official duty, the Agency initiated supervisory proceedings in December 2022 and conducted a procedure in which three previously described violations were established due to negligent conduct by the data controller (the debt collection agency). The data controller bears the highest degree of responsibility for failing to take technical protective measures, as it was precisely due to deficiencies in such a security system that there was insecure processing of a large number of personal data. The debt collection agency lost complete control over the movement of personal data of its respondents and could not explain the causes of unauthorized exfiltration (extraction) of personal data.

Furthermore, as an aggravating circumstance in the conducted administrative procedure, certain deficiencies in cooperation were established. Namely, after several letters sent by the Agency seeking additional clarification or documentation from the data controller, responses were provided only in the last days of the set deadline, and letters were sent for the purpose of extending the deadline and clarifying the requested circumstances, although this could have been requested earlier, which somewhat affected the prolongation of the procedure. Also, in response to multiple requests from the Personal Data Protection Agency for certain documentation (system log extracts), the data controller

did not provide the same. Additionally, as an additional aggravating circumstance, the fact that the data controller has not informed the Agency to this day that it has taken additional protective measures to prevent future risks from established violations has been taken into account, and that to this day it has not adjusted the privacy policy available on its website.

In conclusion, we state that in this specific case, there is a violation of multiple provisions of the General Data Protection Regulation by one of the leading companies in the field of debt collection, which should not have allowed itself to process personal data of a large number of respondents in a non-transparent and insecure manner. Furthermore, the data controller likely would never have noticed the exfiltration of personal data of a large number of respondents, at least for 77,317 of them from their system, had the Personal Data Protection Agency not received an anonymous report and conducted supervisory activities. To this day, the data controller has not clarified all circumstances surrounding the violation, i.e., the disclosure of a certain scope of personal data outside their storage system, which further indicates inadequate protective measures by the data controller.

We also emphasize that in this specific case, there is a possibility of individual criminal liability, i.e., the commission of a criminal offense, which falls under the jurisdiction of the Ministry of the Interior, which is conducting a criminal investigation within its jurisdiction.